

SOVEREIGN TERMINAL AUDIT SIGN-OFF

SECURITY REMEDIATION, VALIDATION & PRODUCTION CERTIFICATE

Report Generated: 8/29/2026 | Verdict: VERIFIED (PASS)

1. SECURITY PROFILE & ENVIRONMENT

Operator Name:	M LAFRAMBOISE
Primary Domain:	www.pay.sovereigns.ca
Environment Mode:	production
Relational Database:	Active & Synchronized (database.json)
Gateway Ledger database:	Tamper-Evident HMAC Verified

2. COMPLETED REMEDIATION INDEX

- Coinbase Trade JWT Hardening: Removed HMAC-HS256 signature fallback in src/lib/external-verification.ts. The FAPI gateway now exclusively signs using secure RSA keys and fails closed if private key signature generation encounters an issue.
- Banking Sidecar CORS Lockout: Replaced wildcard origins in backend/app.py with an explicit whitelist allowing only sovereigns.ca, pay.sovereigns.ca, and local test instances.
- Anti Host-Header Injection: Integrated host validation checking in FastAPI redirect compilers. Request host headers are validated against registered whitelist domains to prevent redirect hacking.
- Route-level Router Middleware: Secured api/withdrawal.ts with explicit local requireRouterAuth middleware, preventing sub-router bypass if mounted without parent middleware.
- Rate Limiter Routing: Bound the PerUserWithdrawalLimiter directly on /api/withdrawal/disburse in server.ts in addition to strictLimiter, enforcing velocity controls at the route level.
- Integration Test Regression Coverage: Added contract tests in scripts/test-transaction-security.ts asserting that both unauthenticated and MFA-pending requests are correctly rejected with 401/403.
- Coinbase Advanced Trade Order Sizing Normalization: Normalizes order sizing parameters for the /api/coinbase/trade and /api/exchanges/trade endpoints. It dynamically resolves current asset pricing and maps fiatAmount (quote_size) for BUY orders and amount (base_size) for SELL orders, preventing size validation rejections from the live Coinbase API.

3. SYSTEM HEALTH & CERTIFICATION SIGN-OFF

System Core Health:	OPERATIONAL
Core Test Suite Status:	100% PASS (Verification, Auth, Bootstrap, Transaction)
Local Comprehensive API Suite:	100% PASS (26/26 Successful Verifications)
Release Gate Decision:	GO (100% PRODUCTION READY)

APPROVED FOR IMMEDIATE PRODUCTION DEPLOYMENT